PHISHING EMAIL DETECTION & AWARENESS REPORT

A Header and Content Analysis of Real-World Phishing Samples

Prepared By	Brian Amani Mlenge
Track	Cyber Security (CS)
Task	Task 02 — Phishing Email Detection & Awareness System
GitHub Repository	FUTURE_CS_02
Sample Source	Phishing Pot public honeypot corpus (rf-peixoto/phishing_pot)
Assessment Type	Email Header Analysis and Content Review
Date	July 2026

1. Introduction

Phishing remains one of the most common ways attackers get into an organization. It doesn't need a technical exploit, just one person clicking the wrong link or typing a password into the wrong form. This report walks through six real phishing emails pulled from a public honeypot dataset, breaks down the technical and behavioral indicators that expose each one, and closes with prevention guidance that a non-technical employee could actually use.

2. Methodology

The samples analyzed here come from Phishing Pot (rf-peixoto/phishing_pot), a public GitHub repository that collects real phishing emails caught by honeypot mailboxes and anonymizes the recipient address before publishing. Six emails were selected out of the corpus to represent a range of attack styles: brand impersonation, account-compromise scams, and bulk spam. Headers were extracted directly from the raw .eml files and examined for sender authentication results, domain consistency, and routing information. Email body content was reviewed separately for social engineering language and link destinations.

One additional email, clearly marked as an authored reference sample rather than a captured phishing sample, is included to illustrate what a legitimate message looks like by comparison, since the honeypot corpus by definition contains only malicious captures and can't supply a genuine Safe baseline on its own.

Tools used: raw header inspection, the phishing_pot dataset, and a text editor for documentation.

Each sample in Section 4 is accompanied by a header-analysis figure summarizing the fields and indicators discussed in the text. These figures were generated directly from the extracted header data of each sample rather than captured from a third-party analyzer tool.

3. What to Look For: Indicator Checklist

Sender authenticity

- **SPF result in Authentication-Results —** a pass means the sending server was authorized to send for that domain, but it does not mean the message is safe, only that it wasn't spoofed at the domain level.
- **Return-Path and Reply-To domains —** if either points somewhere other than the From domain, that's a strong signal the sender wants replies or bounces routed away from where the email claims to originate.

Identity spoofing

- Display name says one thing (“Trust Wallet,” “McAfee,” “Facebook”) while the actual address belongs to an unrelated domain.
- Lookalike character substitution — a capital “I” swapped for a lowercase “l” is nearly invisible in most fonts but changes the word entirely (“WaIlet,” “Iog in”).

Infrastructure

- Sending domain has no business relationship to the claimed brand at all, or is a domain that looks like it was compromised and repurposed.
- Long or unusual Received: chains, or a sending IP that doesn't match the claimed origin.

Content and behavior

- Urgency or fear-based language (“your account will be suspended,” “verify immediately”).
- Offers that are disproportionately generous for an unsolicited email.
- Link text that doesn't match where the link actually goes.

4. Sample Analysis

Sample 1 — Facebook Account Security Impersonation

Verdict: Phishing (High Risk)

Subject line: *“Someone tried to Iog in To Your Account, User ID: [redacted]”*

The From field claims to be Facebook, but the sending domain is unrelated and has no connection to Meta's infrastructure. SPF returns none, meaning the message failed even the basic check for whether the server was allowed to send on that domain's behalf. The Return-Path points to yet a third, different domain, and Reply-To routes to a free email account.

The subject line itself contains the classic character-substitution trick, a capital “I” standing in for a lowercase “l” in both “log” and “ID,” which is meant to slip past simple keyword filters while still reading naturally to a human eye. The urgency framing (“someone tried to log in”) is designed to trigger a panicked click before the recipient stops to check anything.

The header breakdown captured during analysis is shown in Figure 1 below.

HEADER ANALYSIS · SAMPLE 1 — FACEBOOK IMPERSONATION **PHISHING**

Someone tried to log in To Your Account, User ID: [redacted]

FROM	Facebook <5a83h@92e4fsmb2e.com>
REPLY-TO	ssecnewssotrecognizd01@gmail.com
RETURN-PATH	bounce@terdumandeepol.com
AUTH RESULTS	spf=none (sender IP 188.93.118.70)

INDICATORS FOUND

- From, Reply-To, and Return-Path all point to three completely different domains.
- SPF check fails outright — the sender was not authorized to send as this domain.
- Character substitution in subject line ("log", "ID") mimics "log" and "ID" to dodge keyword filters.
- Urgency framing designed to trigger a panicked click.

Figure 1. Header analysis — Facebook Account Security Impersonation

Sample 2 — "Trust Wallet" KYC Verification

Verdict: Phishing (High Risk)

Subject line: *"Your Account KYC is unverified."*

This one is worth slowing down on because SPF actually passes. The sending domain belongs to a real Australian ISP, and the message legitimately came from that infrastructure, but that infrastructure has no relationship whatsoever to Trust Wallet, a cryptocurrency wallet provider.

The display name uses the same lookalike-character trick as Sample 1 ("WaIIet"). This is a useful case for training: a passing SPF check only proves the message wasn't spoofed at the technical level, it says nothing about whether the sender is who they claim to be. The email links to unrelated, unrecognized domains rather than anything resembling Trust Wallet's real site.

The header breakdown captured during analysis is shown in Figure 2 below.

HEADER ANALYSIS · SAMPLE 2 — "TRUST WALLET" KYC SCAM **PHISHING**

Your Account KYC is unverified.

FROM	"Trust WaIIet" <cUSTOMER_sERvICe@tPG.cOm.au>
REPLY-TO	(none set)
RETURN-PATH	cUSTOMER_sERvICe@tpg.com.au
AUTH RESULTS	spf=pass (sender IP 60.241.0.11)

INDICATORS FOUND

- SPF passes — but only proves the real domain (an Australian ISP) wasn't spoofed, not that it's Trust Wallet.
- Display name uses a capital "I" in place of lowercase "l" ("Wallet"), invisible in most fonts.
- Sending domain has zero business relationship to the claimed cryptocurrency brand.
- Embedded links point to unrelated third-party domains, not Trust Wallet's real site.

Figure 2. Header analysis — "Trust Wallet" KYC Verification

Sample 3 — McAfee Subscription Renewal

Verdict: Phishing (High Risk)

Subject line: *"Ihr McAfee-Abonnement läuft ab, verlängern Sie es jetzt" (German: "Your McAfee subscription is expiring, renew it now")*

The sending domain has no connection to McAfee and appears to be an unrelated business's mail domain, sent through a bulk email relay service. The Reply-To address lands on yet another unrelated domain, separate from both the sender and the claimed brand.

This layering, three different domains involved in one message, is a common pattern once an attacker starts using commercial email infrastructure to get better deliverability rates than a random domain would achieve on its own. The renewal urgency is standard fear-of-loss social engineering.

The header breakdown captured during analysis is shown in Figure 3 below.

HEADER ANALYSIS · SAMPLE 3 — MCAFEE RENEWAL SCAM PHISHING

Ihr McAfee-Abonnement läuft ab, verlängern Sie es jetzt

FROM	"Mcafee™" <support@gurturmadencilik.com>
REPLY-TO	reply@peeksealing.work
RETURN-PATH	bounces-...@gurturmadencilik.com
AUTH RESULTS	spf=pass (sender IP 20.246.44.102)

INDICATORS FOUND

- Three separate domains involved: sending domain, Reply-To domain, and the claimed brand — none match.
- Sending domain has no connection to McAfee; message routed through a bulk commercial relay.
- SPF passing for the relay domain does not validate the McAfee brand claim.
- Subscription-expiry urgency is classic fear-of-loss social engineering.

Figure 3. Header analysis — McAfee Subscription Renewal

Sample 4 — "Successful Transfer" (Compromised Account)

Verdict: Phishing (High Risk) — Compromised Account, Not Spoofed

Subject line: *"Successful Transfer"*

This sample is the most instructive of the six because everything at the header level checks out. SPF passes, the domain is real, and it belongs to an actual media organization. What makes this phishing isn't a spoofed header, it's that the account itself was very likely compromised and used to send an advance-fee cryptocurrency scam ("your wallet has been funded with 140 BTC, log in with the details below to confirm") to an external, unrelated site.

This matters for awareness training because it proves header analysis alone isn't sufficient. A message can pass every authentication check and still be malicious if the account sending it no longer belongs to the person it claims to.

The header breakdown captured during analysis is shown in Figure 4 below.

HEADER ANALYSIS · SAMPLE 4 — COMPROMISED CORPORATE ACCOUNT **PHISHING**

Successful Transfer

FROM	"Pasic, Tarik" <tpasic@ruptly.tv>
REPLY-TO	(none set)
RETURN-PATH	**tpasic@ruptly.tv**
AUTH RESULTS	**spf=pass (sender IP 212.91.248.116)**

INDICATORS FOUND

- Every header field checks out — real domain, real employee, SPF passes cleanly.
- Risk is not a spoofed header but a likely-compromised legitimate account.
- Body content pitches an advance-fee cryptocurrency scam ("wallet funded with 140 BTC") unrelated to the sender's real job.
- Proves header checks alone are not sufficient — content review is still required.

Figure 4. Header analysis — "Successful Transfer" (Compromised Account)

Sample 5 — Casino Bonus Spam

Verdict: Suspicious (Medium Risk)

Subject line: *"Claim Your Free 400 FREE SPINS Welcome Bonus!"*

Both SPF and DKIM pass here, and the domain is internally consistent, it's simply a domain built for bulk marketing rather than a domain with any tie to an actual casino brand. There's no credential harvesting attempt and no brand impersonation of a specific company, just an unsolicited, too-good-to-be-true offer.

This one is classified as Suspicious rather than outright Phishing because the intent looks closer to aggressive spam marketing than an attempt to steal credentials or money directly, though clicking through still carries real risk.

The header breakdown captured during analysis is shown in Figure 5 below.

HEADER ANALYSIS · SAMPLE 5 — CASINO BONUS SPAM **SUSPICIOUS**

Claim Your Free 400 FREE SPINS Welcome Bonus!

FROM	"Casino rewards" <LolaJackCasino@onetowash.com>
REPLY-TO	(none set)
RETURN-PATH	**<empty>**
AUTH RESULTS	**spf=pass, DKIM present (sender IP 139.162.38.168)**

INDICATORS FOUND

- SPF and DKIM both pass and are internally consistent for the sending domain.
- Domain is bulk-marketing infrastructure with no real tie to a casino brand.
- No credential harvesting attempt observed — unsolicited offer rather than direct theft.
- Empty Return-Path is typical of high-volume bulk mail.

Figure 5. Header analysis — Casino Bonus Spam

Sample 6 — "Stellar Development Foundation" Staking Offer

Verdict: Phishing (High Risk)

Subject line: *"Stake your XLM for 25% yields"*

The claimed sender is the Stellar Development Foundation, a real cryptocurrency organization, but the actual sending domain appears to belong to an Australian pediatric medical practice, almost certainly a domain whose mail server was compromised or misconfigured and is now being abused to relay spam. SPF returns none.

A guaranteed 25% yield is not a claim any legitimate financial or crypto organization would make, since it promises a fixed, risk-free return that doesn't exist in real markets.

The header breakdown captured during analysis is shown in Figure 6 below.

HEADER ANALYSIS · SAMPLE 6 — COMPROMISED DOMAIN RELAY **PHISHING**

Stake your XLM for 25% yields

FROM	Stellar Development Foundation <noreply@mpzcs.manukapaediatrics.com.au>
REPLY-TO	(none set)
RETURN-PATH	**office393@mpzcs.manukapaediatrics.com.au**
AUTH RESULTS	**spf=none (sender IP 180.200.129.176)**

INDICATORS FOUND

- Claimed sender (a real crypto foundation) has no relationship to the sending domain, which belongs to a medical practice.
- SPF fails outright — domain almost certainly compromised or misconfigured and abused to relay spam.
- Guaranteed 25% yield is not a claim any legitimate financial organization makes.
- Return-Path domain matches the compromised medical practice, not the claimed brand.

Figure 6. Header analysis — "Stellar Development Foundation" Staking Offer

Sample 7 — (Reference) Legitimate Account Notification

Verdict: Safe

Note: this sample was written by the author as a comparison reference, not captured from a live source.

Subject line: *"Your monthly account statement is ready"*

A genuine notification from a real service typically sends from the organization's actual domain, with From, Return-Path, and Reply-To all aligned to that same domain, no urgency language, no request to "verify" or "confirm" credentials through an embedded link, and any link present goes to the organization's own domain rather than a third party.

Comparing this side by side with Samples 1 through 6 makes the contrast in domain consistency and language tone much clearer than the negative examples can show on their own.

5. Risk Classification Summary

Sample	Claimed Sender	Actual Domain	SPF	Classification
1	Facebook	Unrelated domain	None	Phishing
2	Trust Wallet	Unrelated (real) ISP domain	Pass	Phishing
3	McAfee	Unrelated business domain	Pass	Phishing
4	Real employee (media org)	Legitimate, own domain	Pass	Phishing (compromised account)
5	Casino brand	Bulk-marketing domain	Pass	Suspicious
6	Stellar Development Foundation	Unrelated (compromised) domain	None	Phishing
7	(reference) legitimate service	Matches claimed domain	Pass	Safe

6. Prevention & Awareness Guidelines

- **Check the actual sending address, not just the display name.** A message can say "Facebook" or "McAfee" in the name field while the address behind it belongs to a completely unrelated domain.
- **A passing SPF/DKIM check is not proof of legitimacy.** It only confirms the message wasn't spoofed at the domain level, not that the sender is honest or that the account hasn't been compromised.

- **Slow down on urgency.** Legitimate organizations rarely demand immediate action through email alone, especially for account security or financial matters.
- **Hover before clicking.** Compare the visible link text to where it actually points before following it.
- **Be skeptical of guaranteed returns or free money.** No legitimate financial offer promises fixed, risk-free gains.
- **Report, don't just delete.** Forwarding suspicious emails to IT/security teams helps them block the sender and warn other employees before more people receive it.

7. Conclusion

None of these six phishing emails relied on sophisticated technical exploits. They relied on trust: trust in a familiar brand name, trust in an urgent-sounding subject line, trust in a colleague's email address. Header analysis catches most of them, but Sample 4 shows its limits, since authentication checks can pass cleanly while the account behind them has already been compromised. Real phishing defense combines technical verification with the same instinct any careful person should have anyway, pausing before acting on an email that asks for money, credentials, or urgent action.

8. References

Phishing Pot dataset: https://github.com/rf-peixoto/phishing_pot